

chức năng:

Nhóm	Chức năng	Mô tả ngắn
1. Đăng ký & Xác minh	✓ Đăng ký người dùng mới	Nhận thông tin đăng ký, lưu DB, gửi mail hoặc OTP.
	✓ Xác minh email / số điện thoại	Kích hoạt tài khoản thông qua mã xác minh.
2. Đăng nhập / Đăng xuất	✓ Đăng nhập	Xác thực username/password, tạo JWT token.
	✓ Refresh Token	Cấp lại token mới khi token cũ sắp hết hạn.
	✓ Đăng xuất	Thu hồi refresh token, vô hiệu hoá session.
3. Quản lý người dùng & quyền hạn	✓ Phân quyền & vai trò (User–Role)	Gán Role, quản lý quyền truy cập endpoint.
	✓ Khóa tài khoản sau nhiều lần sai mật khẩu	Đặt trạng thái LOCKED nếu đăng nhập sai quá số lần quy định.
4. Quản lý phiên / token	✓ Quản lý phiên đăng nhập	Theo dõi user login, token còn hiệu lực không.
	✓ Quản lý token JWT & Refresh token	Lưu DB, blacklist token khi logout.
	✓ Cung cấp endpoint xác thực cho các service khác	/auth/validate, /auth/introspect để các service khác gọi xác minh token.
5. Bảo mật nâng	🔒 Quên mật khẩu / reset	Gửi link reset qua email.

cao (tùy chọn)	mật khẩu	
	🔒 MFA (xác thực 2 yếu tố – nếu muốn nâng cao)	Thêm bước OTP khi đăng nhập.
	🔒 Log hoạt động / audit	Ghi nhận ai đăng nhập, đăng xuất, thay đổi quyền.

♦ 1. Đăng ký người dùng mới (/register)

Layer	Nhiệm vụ cụ thể
Entity	Đã có <code>User</code> entity → đảm bảo có các trường: <code>email</code> , <code>password</code> , <code>role</code> , <code>status</code> , <code>verificationCode</code> , <code>isVerified</code> .
Repository	<code>UserRepository</code> có method <code>findByEmail()</code> để kiểm tra trùng.
Service	Tạo <code>registerUser(RegisterRequest)</code> → encode password, tạo <code>verificationCode</code> , lưu user, gửi email xác minh.
Controller	Tạo endpoint <code>POST /auth/register</code> → gọi service.
SecurityConfig	Cho phép endpoint <code>/auth/register</code> public (permitAll).

♦ 2. Xác minh email (/verify)

Layer	Nhiệm vụ cụ thể
Entity	Trường <code>verificationCode</code> , <code>isVerified</code> .
Repository	<code>findByVerificationCode(String code)</code> .
Service	<code>verifyEmail(String code)</code> → tìm user, đổi <code>isVerified=true</code> , <code>status=ACTIVE</code> .

Controller	Endpoint <code>GET /auth/verify?code=xxx</code> .
-------------------	---

SecurityConfig	<code>PermitAll</code> .
-----------------------	--------------------------

♦ 3. Đăng nhập / Tạo JWT (`/login`)

Layer	Nhiệm vụ cụ thể
Entity	Không thay đổi.
Repository	<code>findByEmail()</code> .
Service	<code>authenticate(LoginRequest)</code> → dùng <code>AuthenticationManager</code> kiểm tra username/password, sinh JWT + Refresh Token, lưu Refresh Token vào DB.
Controller	<code>POST /auth/login</code> trả về <code>{ accessToken, refreshToken }</code> .
SecurityConfig	<code>PermitAll /auth/login</code> .

♦ 4. Refresh Token (`/refresh`)

Layer	Nhiệm vụ cụ thể
Entity	Bảng <code>refresh_token</code> (user_id, token, expiry, revoked).
Repository	<code>findByToken()</code> .
Service	<code>refreshToken(String refreshToken)</code> → kiểm tra hợp lệ, sinh mới accessToken.
Controller	<code>POST /auth/refresh</code> .

ller

♦ 5. Đăng xuất (**/logout**)

Layer	Nhiệm vụ cụ thể
Entity	RefreshToken.
Service	Xoá hoặc đánh dấu revoked=true .
Controller	POST /auth/logout .
SecurityConfig	Chỉ cho phép user đang đăng nhập.

♦ 6. Phân quyền & Gán vai trò (User-Role)

Layer	Nhiệm vụ cụ thể
Entity	User có Set<Role> hoặc Role role (tùy thiết kế).
Repository	RoleRepository .
Service	CRUD cho Role, gán role cho user.
Controller	/role/* , /user/{id}/role .
SecurityConfig	Dùng @PreAuthorize("hasRole('ADMIN')).

♦ 7. Khóa tài khoản sau nhiều lần sai mật khẩu

Layer	Nhiệm vụ cụ thể
Entity	Thêm trường <code>failedAttempts</code> , <code>lockTime</code> , <code>accountNonLocked</code> .
Service	Khi login sai → tăng <code>failedAttempts</code> , nếu vượt ngưỡng → <code>accountNonLocked=false</code> .
Controller	Không cần riêng.
Security	Dùng custom <code>UserDetailsService</code> đọc trạng thái <code>accountNonLocked</code> .

♦ 8. Endpoint xác thực cho các service khác (`/validate`, `/introspect`)

Layer	Nhiệm vụ cụ thể
Service	<code>validateToken(String token)</code> → xác minh chữ ký JWT, thời hạn.
Controller	<code>/auth/validate</code> hoặc <code>/auth/introspect</code> (POST, body chứa token).
SecurityConfig	Cho phép gọi nội bộ (chỉ các service khác). Dùng <code>api-key</code> hoặc <code>internal-client-secret</code> .

♦ 9. Quên mật khẩu (tùy chọn)

Layer	Nhiệm vụ cụ thể
Entity	Thêm <code>resetPasswordToken</code> , <code>resetPasswordExpiry</code> .
Service	Gửi mail link reset, đổi mật khẩu.

e

Controller `/auth/forgot-password,
/auth/reset-password.`

✓ III. Đề xuất Thứ Tự Thực Hiện

1. Đăng ký + Xác minh email (để có người dùng hợp lệ)
 2. Đăng nhập + JWT + Refresh token
 3. Đăng xuất + Token quản lý
 4. Phân quyền + Role
 5. Khóa tài khoản sau nhiều lần sai
 6. Endpoint validate cho service khác
 7. (Tuỳ chọn) Quên mật khẩu, audit log
-